

COLONIAL PIPELINE RANSOMWARE (2021)

Ransomware · No MFA · East Coast Fuel Crisis · \$4.4M Ransom Paid

THIS PROJECT: Understand what happened, map the attack, research the CVE. This project ends with a CVE Research Worksheet (50 points).

CVE / ADVISORY: No CVE — stolen VPN password, no MFA. Research CISA Alert AA21-131A (DarkSide Ransomware).

INCIDENT OVERVIEW

On May 7, 2021, Colonial Pipeline — operator of the largest fuel pipeline in the United States supplying 45% of the East Coast's fuel — suffered a ransomware attack by the DarkSide criminal group. Attackers accessed the network using a single compromised VPN password found on the dark web. There was NO multifactor authentication on that account. Colonial proactively shut down pipeline operations fearing ransomware would spread to OT systems, triggering fuel shortages across 17 states. Colonial paid \$4.4 million in Bitcoin ransom within hours. The FBI later recovered \$2.3 million.

KEY FACTS AT A GLANCE

- Entry point: ONE compromised VPN password found on the dark web — NO multifactor authentication
- Attacker group: DarkSide (ransomware-as-a-service criminal organization)
- 100GB of data exfiltrated BEFORE ransomware was deployed (double-extortion)
- Colonial proactively shut down 5,500 miles of pipeline — OT systems were NOT infected
- Fuel shortages across 17 states — national emergency declared by President Biden
- \$4.4 million Bitcoin ransom paid; FBI later recovered \$2.3 million of it
- DarkSide shut down operations shortly after the attack

PROJECT 3 · DAY 1

MONDAY — INCIDENT INTRODUCTION + CIA TRIAD

1-2 HRS

OBJECTIVE: Students understand the Colonial Pipeline Ransomware at a high level and apply the CIA Triad to identify which pillars were violated and how.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:15	Welcome & Project Overview	Distribute Project 3 packet. Explain: this project is about understanding exactly what happened. Next project we apply frameworks and write the executive summary.
0:15-0:45	Lecture: CIA Triad	Teach Confidentiality, Integrity, Availability. Use real-world examples. Ask: what happens when each one fails?
0:45-1:10	Read the Incident	Students read the Incident Overview (15 min silent). Then open discussion: What happened? What was your first reaction?
1:10-1:50	CIA Triad Mapping Activity	Students fill out their CIA Triad worksheet — which pillars were violated, specific evidence, impact rating (Low/Med/High/Critical).
1:50-2:00	Debrief & Homework	Share out. Homework: Write a 1-paragraph plain-English explanation of the incident for a non-technical reader.

PROJECT 3 • DAY 2

TUESDAY — CYBER KILL CHAIN — ALL 7 PHASES

1-2 HRS

OBJECTIVE: Students map the complete attack through all 7 Kill Chain phases using specific incident evidence.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Lecture: Kill Chain	Teach the 7 phases. For each: what does the attacker do? At what point could a defender have stopped this?
0:30-1:00	Demo: Phase Walkthrough	Walk through ONE Kill Chain phase together as a class. Model your analysis process out loud.
1:00-1:45	Kill Chain Mapping	Students complete the full Kill Chain table — all 7 phases with specific incident evidence, not generic descriptions.
1:45-2:00	Discussion	Which phase was the most preventable? Which phase was most surprising? What would have stopped the attack?

PROJECT 3 • DAY 3

WEDNESDAY — MITRE ATT&CK — HANDS-ON LAB

1-2 HRS

OBJECTIVE: Students identify specific ATT&CK techniques, navigate attack.mitre.org, and explain each technique in plain English.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:30	Lecture: MITRE ATT&CK	Explain Tactics (the WHY), Techniques (the HOW), Procedures (the specific implementation). Show the ATT&CK Navigator.
0:30-0:50	Live Demo: attack.mitre.org	Navigate the matrix together. Look up ONE technique from this incident. Show the description, procedure examples, and detection methods.
0:50-1:40	ATT&CK Research Lab	Students identify 3-5 techniques from the incident. For each: ID, name, tactic, and plain-English explanation.
1:40-2:00	Class ATT&CK Heat Map	Build a shared map on the board. Students add techniques. What does the pattern tell us about where to focus defenses?

PROJECT 3 • DAY 4	THURSDAY — CVE RESEARCH LAB + WORKSHEET SUBMISSION (50 PTS)	1-2 HRS
--------------------------	--	----------------

OBJECTIVE: Students research the CVE or CISA advisory, build the incident timeline, finalize and submit the CVE Research Worksheet.

CLASS SCHEDULE

TIME	ACTIVITY	DETAIL / INSTRUCTIONS
0:00-0:20	CVE Orientation	Walk students through nvd.nist.gov and cisa.gov . Show them how to read a CVE entry: description, CVSS score, references.
0:20-1:10	Research Lab + Worksheet	Students research: CISA AA21-131A (DarkSide Ransomware), TSA Pipeline Security Directive SD-02B. Document: patch/fix, when available, how the incident was contained, who was involved.
1:10-1:40	Timeline + Finalization	Students build the incident timeline. Finalize the CVE Research Worksheet. Instructor circulates to answer last-minute questions.
1:40-2:00	Submit + Next Project Preview	Students submit completed CVE Research Worksheet (50 points). Open discussion: What surprised you? Preview next project: NIST CSF, attacker methodology, and Executive Summary.

KILL CHAIN REFERENCE — FULL ANALYSIS

PHASE	WHAT HAPPENED IN THIS INCIDENT	DEFENDER OPPORTUNITY
1. Reconnaissance	Searched dark web credential dumps for Colonial Pipeline employee VPN passwords	Threat intelligence; dark web monitoring; monitor vendor relationships

PHASE	WHAT HAPPENED IN THIS INCIDENT	DEFENDER OPPORTUNITY
2. Weaponization	DarkSide ransomware-as-a-service platform prepared; exfiltration tools ready	Patch management; secure development practices; code signing
3. Delivery	Used compromised VPN credentials to authenticate directly — no MFA meant one password was all it took	Email filtering; MFA; user security awareness training
4. Exploitation	Immediate, unrestricted access to Colonial's corporate IT network — no additional barriers	Patch known CVEs; WAF; regular penetration testing
5. Installation	Exfiltrated 100GB first; then deployed DarkSide ransomware across IT systems	File integrity monitoring; application whitelisting; EDR
6. Command & Control	DarkSide infrastructure provided C2; ransomware confirmed deployment and received encryption keys	DNS filtering; SSL inspection; anomaly detection on outbound traffic
7. Actions on Obj.	Encrypted Colonial's IT files; threatened to publish 100GB of stolen data publicly	Data loss prevention (DLP); database activity monitoring; network segmentation

MITRE ATT&CK TECHNIQUE REFERENCE

TECHNIQUE ID	TECHNIQUE NAME	HOW IT WAS USED
T1078	Valid Accounts	Used a compromised employee VPN password found on the dark web
T1133	External Remote Services	Exploited Colonial's VPN — an external remote access service — as the entry point
T1486	Data Encrypted for Impact	DarkSide ransomware encrypted IT systems — core ransomware technique
T1490	Inhibit System Recovery	Deleted shadow copies and backup files to prevent recovery without paying ransom
T1048	Exfiltration Over Alt Protocol	Exfiltrated 100GB before deploying ransomware for double-extortion leverage

CVE / ADVISORY REFERENCE

IDENTIFIER: No CVE — stolen VPN password, no MFA. Research CISA Alert AA21-131A (DarkSide Ransomware).

HOW IT WAS PATCHED

- No software patch — the vulnerability was a missing process control (MFA)
- Colonial immediately implemented MFA on VPN and all remote access systems post-incident
- TSA issued mandatory Security Directive SD-Pipeline-2021-01 requiring pipeline operators to report incidents within 12 hours
- TSA later issued SD-02B requiring MFA, network segmentation, and continuous monitoring
- All VPN credentials rotated; compromised account disabled

HOW THE INCIDENT WAS CONTAINED

- Colonial paid \$4.4M Bitcoin ransom and received DarkSide decryption tool
- FBI seized \$2.3M from DarkSide's Bitcoin wallet on June 7, 2021
- Pipeline restarted May 12, 2021 — 5 days after shutdown
- DarkSide shut down operations (possibly due to law enforcement pressure)
- President Biden declared national emergency; fuel transport regulations waived

INCIDENT TIMELINE

DATE	EVENT
May 7, 2021 ~5AM	DarkSide ransomware deployed; Colonial detects and shuts down pipeline
May 7, 2021	Colonial pays \$4.4M Bitcoin ransom
May 9, 2021	President Biden declares national emergency; 17 states face fuel shortages
May 12, 2021	Pipeline fully restarted after receiving decryption key
May 14, 2021	DarkSide announces shutdown of operations
June 7, 2021	DOJ announces recovery of \$2.3M from DarkSide Bitcoin wallet
July 2021	TSA issues mandatory pipeline cybersecurity directives

PROJECT 3 ASSESSMENT — CVE RESEARCH WORKSHEET (50 POINTS)

DUE: Thursday of this project. Submit to your instructor.

[10 pts] What is the CVE number and CVSS score for this incident? If no CVE exists, what CISA advisory or identifier applies? What does the CVSS score (or the absence of a CVE) tell you about the nature of this vulnerability?

[10 pts] Describe the vulnerability or weakness in your own words — plain English, no jargon. A non-technical reader should completely understand what went wrong.

[10 pts] When was the official patch or fix released? How much time passed between the fix being available and the breach occurring? What does that timeline tell you about the organization's security practices?

[10 pts] Who was involved in containing this incident? What specific actions were taken? How long did full containment take?

[10 pts] List your 3 most critical "From Here On Out" recommendations for any organization that uses similar technology. For each, explain specifically WHY it would have prevented or reduced this breach.

REFERENCES & RESOURCES

- CISA Alert AA21-131A: "DarkSide Ransomware: Best Practices" — [cisa.gov](https://www.cisa.gov)
- U.S. Senate Homeland Security Committee: Colonial Pipeline CEO Testimony (June 8, 2021)
- DOJ Press Release: "Department of Justice Seizes \$2.3 Million in Cryptocurrency Paid to DarkSide" (June 7, 2021)
- TSA Pipeline Security Directive SD-02B — [tsa.gov](https://www.tsa.gov)
- MITRE ATT&CK: attack.mitre.org — search T1078, T1486, T1490
- CISA Ransomware Guide: [cisa.gov/ransomware](https://www.cisa.gov/ransomware)